

Para ello es importante adaptar los perfiles de las personas incorporando competencias TIC, adaptadas al papel que jugarán en relación a los Sistemas de Información. En la siguiente figura se pone de manifiesto la orientación del perfil profesional requerido para las distintas funciones presentadas en el apartado anterior.



Figura 55

Uno de los principales retos para la dirección es el lograr una organización en la que las personas cuenten con las competencias adecuadas en función del puesto ocupado, que le permitan decidir qué soluciones se requieren, participar en su implantación y utilizar las correspondientes a su función.

En la siguiente tabla se presenta a título indicativo una orientación del perfil profesional de diversos puestos en una empresa:

FUNCIÓN	ORIENTACIÓN DEL PERFIL PROFESIONAL
DIRECCIÓN GENERAL	Con conocimientos, destrezas y actitudes que le permitan fomentar el cambio y liderar la introducción de las Tecnologías de la Información en la organización, así como participar en la definición (planificación) de los sistemas a introducir y utilizar los correspondientes a la dirección (sistemas de apoyo a la decisión, Internet/Intranet, ofimática, agendas electrónicas...).
DIRECCIÓN FUNCIONAL	Con conocimientos, destrezas y actitudes que le permitan participar en la planificación de los sistemas, así como en la implantación de los correspondientes a su área de actividad. Deberá conocer las oportunidades que las TIC ofrecen en el área de trabajo y las claves para su correcta implantación. Ofrecerá así mismo un perfil adecuado como usuario de los sistemas que correspondan a su área de actividad (ERP, ofimática, Internet/Intranet, agendas electrónicas...).
NIVEL OPERATIVO	Con conocimientos, destrezas y actitudes para aprovechar el potencial de las TIC en su función, que sepa utilizar las aplicaciones que se requieran en cada caso: ingeniería, diseño, Internet, ofimática, etc.
DIRECCIÓN DE SISTEMAS DE INFORMACIÓN	Deberá aportar capacidades relacionadas tanto con la organización, como con las tecnologías que le permitan intervenir en la planificación. Se responsabilizará de la gestión de los proyectos relacionados con las TIC en las empresas, así como en las funciones de gestión de los sistemas (dirección de los proyectos de desarrollo, relación con las diferentes áreas, mantenimiento de los sistemas, gestión de redes, administración de sistemas, contratación...)
FUNCIONES ESPECÍFICAS RELACIONADAS CON ACTIVIDADES DEL DEPARTAMENTO DE TIC	
GESTIÓN Y ADMINISTRACIÓN DE REDES Y SISTEMAS	Aportará las capacidades para la gestión de la infraestructura de equipamiento, sistemas operativos y redes existentes en la organización (diseño, administración, mantenimiento, soporte a usuarios...).
GESTIÓN Y ADMINISTRACIÓN DE TELECOMUNICACIONES	Aportará las capacidades para el diseño, selección y aplicación de las soluciones que requieran la aplicación de redes y servicios de telecomunicación.

FUNCIÓN	ORIENTACIÓN DEL PERFIL PROFESIONAL
GESTIÓN Y ADMINISTRACIÓN DE APLICACIONES INFORMÁTICAS	Aportará las capacidades para la gestión de las aplicaciones requeridas en la empresa (participar en el diseño, selección, adquisición, implantación y administración de aplicaciones y bases de datos, soporte a usuarios).
DESARROLLADOR DE APLICACIONES	Con capacidad para el análisis y diseño de aplicaciones informáticas.

Como conclusión final, conviene destacar, una vez más, la necesidad de enfocar el proceso de implantación de los Sistemas y Tecnologías de la Información con una triple óptica que considere de forma equilibrada los componentes humanos, organizativos y tecnológicos.

PLANIFICACIÓN DE LOS SISTEMAS DE INFORMACIÓN

Mediante el Plan de Sistemas de Información la empresa establece los objetivos y proyectos relativos a los Sistemas de Información, de forma alineada con los propios objetivos de la empresa.

El cometido del plan es el siguiente:

- Alinear los objetivos de la empresa con los Sistemas de Información previstos, e integrar a la dirección general en las decisiones relativas a los sistemas.
- Dotar a la empresa de sistemas que puedan responder verdaderamente a las necesidades organizativas, tanto para los procesos de trabajo como para la toma de decisiones.
- Implicar a los distintos responsables en las decisiones que van a afectar al futuro de los sistemas relacionados con sus funciones o departamentos.

- Diseñar la transición presente-futuro y servir como base para la gestión de los proyectos que se originen en el plan incluyendo calendarios, responsables, políticas que se van a seguir, recursos previstos, etc.

Las fases implicadas en el proceso de elaboración del Plan de Sistemas de Información son las que se resumen en la siguiente tabla:

Tabla 13. Fases para la elaboración de un Plan de Sistemas de Información

FASES PARA LA ELABORACIÓN DE UN PLAN DE SISTEMAS DE INFORMACIÓN	
Fases	Descripción
Fase 1	Establecimiento del equipo de trabajo
Fase 2	Análisis de la situación actual y de las oportunidades
Fase 3	Establecimiento de las directrices del plan
Fase 4	Diseño de la arquitectura de aplicaciones futuras
Fase 5	Formalización de planes y calendarios
Fase 6	Estudio de recursos necesarios
Fase 7	Estudio económico y rentabilidad
Fase 8	Elaboración y Presentación del plan

Fase 1: Establecimiento del equipo de trabajo

El cometido de esta fase es establecer el grupo que se encargará de diseñar el plan y las acciones que se prevé realizar: entrevistas, calendarios, visitas, presentaciones preliminares, etc.

Normalmente se suele establecer una Comisión de Sistemas que integra a la propia dirección general, a la dirección de sistemas y a los

principales responsables funcionales. Como responsable de la elaboración del documento suele nombrarse al Responsable de Sistemas.

La realización de un plan de sistemas debe comunicarse a todos los responsables de la organización, ya que se verán implicados en la aportación de sugerencias, necesidades departamentales, etc. Dicha comunicación debería realizarse de forma directa, mediante reunión o bien mediante un comunicado interno.

Fase 2: Análisis de la situación actual y de las oportunidades

El diseño del plan debe partir de una visión adecuada de los sistemas actuales: carencia de información, problemas organizativos, limitaciones de las aplicaciones informáticas actuales, etc. También deben tenerse presentes las oportunidades estratégicas que darán lugar normalmente a nuevas aplicaciones o sistemas o rediseño de las actuales.

Para analizar la situación actual debería aplicarse una doble óptica: la organizativa y la de los sistemas disponibles. Desde el punto de vista organizativo es necesario mantener entrevistas con los distintos responsables para determinar los procesos que se realizan y las limitaciones actuales en lo que se refiere a su coordinación y el manejo de la información que sería necesaria. Para llevar a cabo esta tarea existen diversas metodologías para establecer la dinámica de entrevistas con usuarios, clasificar los problemas o establecer prioridades.

NECESIDADES DEPARTAMENTALES	DEPARTAMENTO 1	DEPARTAMENTO 2	DEPARTAMENTO 3	DEPARTAMENTO 4	DEPARTAMENTO ...
Necesidad 1					
Necesidad 2					
Necesidad 3					
.....					
.....					
.....					
.....					
.....					
.....					
Necesidad n					

Figura 56. Matriz de análisis de las necesidades departamentales

Como resultado de este trabajo puede obtenerse un “listado” de los problemas actuales, sus causas, posibles soluciones, departamentos afectados, etc. La implicación de los distintos departamentos es fundamental, ya que permite obtener una visión más real de la “utilización” de los sistemas actuales y de las necesidades no cubiertas.

Es importante que la Comisión de Sistemas valore las distintas sugerencias planteadas a nivel departamental e incorpore las prioridades de la organización completa, así como aspectos que puedan afectar al conjunto y que no se reflejen en las entrevistas con los distintos departamentos. La Comisión de Sistemas introduce además la componente “estratégica” en el plan, incorporando los objetivos y prioridades a nivel global, que tendrán su reflejo en las aplicaciones y prioridades en el plan de sistemas.

También para este tema existen metodologías que ayudan a identificar las áreas de aplicación estratégica de las TIC, basadas sobre todo en herramientas matriciales que ayuden a vincular los objetivos

estratégicos de la organización y los factores críticos de éxito con el portfolio de aplicaciones necesarias a nivel de sistemas. En la figura se presenta una tabla de ayuda a la identificación de oportunidades de nuevos sistemas, vinculados a factores clave de la organización.

FACTORES CLAVE DE COMPETITIVIDAD / PROYECTOS	MARKETING - COMERCIALIZACION	ATENCION CLIENTE	RELACION PROVEEDORES	MEJORA PROCESOS	MEJORA CONOCIMIENTO	INNOVACION Y DESARROLLO	GESTION DE RECURSOS	REDUCCION DE COSTES
Proyecto 1								
Proyecto 2								
Proyecto 3								
Proyecto 4								
.....								
.....								
.....								
.....								
Proyecto n								

Figura 57. Matriz de identificación de proyectos vinculados a factores clave de competitividad

Ya desde un punto de vista más informático es preciso valorar la situación actual a nivel de Tecnologías de la Información y la Comunicación, que se concreta en:

1. *Hardware* e infraestructura de comunicaciones

Debería presentarse de forma clara el inventario de elementos, tanto los centrales (servidores, impresoras, equipos de red...) como los departamentales (puestos de usuario, impresoras, etc.).

Conviene considerar en relación al *hardware* los aspectos más determinantes para los cambios: número de equipos, configuración actual, valoración económica...

2. Aplicaciones

En relación a las aplicaciones informáticas conviene distinguir los sistemas por niveles: *software* específico aplicado por la dirección, ofimática, *software* específico de algún departamento, *software* de gestión.

La descripción y valoración de las aplicaciones debería incluir los siguientes aspectos: función desarrollada, proveedor, usuarios y otros agentes implicados, limitaciones actuales y cualquier comentario que pueda ser de interés para la planificación de posibles cambios.

Fase 3: Establecimiento de las directrices del plan

La dirección de la empresa debe establecer qué espera de los Sistemas de Información a nivel empresa, definiendo así la orientación del plan. Algunos aspectos adicionales suelen ser también líneas directrices de los planes a diseñar:

- Políticas a seguir en relación a la implantación de paquetes *software*, concretamente la decisión de comprar o hacer.
- Decisiones sobre los sistemas antiguos: aprovechamiento o no de los mismos en los nuevos sistemas.
- Criterios de dirección que nos ayuden a priorizar las acciones y aplicaciones del plan que se va a acometer.
- Expectativa sobre los presupuestos a comprometer en el plan.

Fase 4: Arquitectura de las aplicaciones futuras

En el plan deberían quedar definidas las futuras aplicaciones a implantar en la empresa. Además de la lista de las aplicaciones debería establecerse una *modularización* que permita definir proyectos diferentes perfectamente delimitados, haciendo un especial énfasis en la integración de los distintos módulos.

Para cada una de las aplicaciones debería incluirse una recomendación sobre la posible adquisición de un paquete de mercado o la necesidad de desarrollo, personalización, etc.

Para cada una de las aplicaciones deberá establecerse una descripción funcional básica de los requisitos que ésta ha de cubrir, de tal modo que quede suficientemente claro el alcance y las principales características del sistema a implantar.

Fase 5: Elaboración del Plan

El Plan de Sistemas debe detallar:

- Plan de aplicaciones a desarrollar e implantar, incorporando las fechas y responsables para cada una de las distintas aplicaciones.
- Plan de *hardware* e instalaciones.
- Plan de comunicaciones, si procede.
- Migración de datos de sistemas anteriores.
- Plan de formación y puesta en marcha de los distintos sistemas.

Algunas empresas (grandes) suelen incorporar el concepto de planes por departamento, que resumen los objetivos previstos, acciones a realizar y fechas previstas para incorporar nuevos sistemas en cada uno de los departamentos. Se trata de una selección de los planes generales por departamentos.

Un aspecto importante en todo Plan de Sistemas debería ser la identificación de los responsables de cada uno de los proyectos. Es importante asignar dicha responsabilidad a los directivos funcionales a los que se refiera cada proyecto en cuestión, salvo que se trate de un proyecto global, en el que debería asignarse un responsable concreto, o un proyecto de infraestructuras o equipamiento, en el que el responsable será el director de sistemas.

En definitiva, cada proyecto importante debería tener un responsable que se encargue de impulsar y liderar el proyecto. En el caso de proyectos dirigidos a la implantación de un sistema que afecte a procesos concretos de una organización, lo más adecuado es que sea el propio responsable de dicho proceso el que asuma dicho papel.

Fase 6: Recursos necesarios

Al igual que se han formulado planes para alcanzar los objetivos previstos, es preciso analizar la disponibilidad de recursos para acometer dichos planes. Por tanto, este aspecto debe realizarse en paralelo con la planificación general de los sistemas.

Entre los aspectos más destacables, cabe indicar la posible necesidad de contratación de personal para el desarrollo de sistemas o el *outsourcing* de ciertas aplicaciones o sistemas.

El estudio de los recursos necesarios debe incluir:

- Recursos Humanos del Departamento de Sistemas.
- Recursos Humanos de otros departamentos de la empresa.
- Recursos externos: proveedores.
- Otros recursos necesarios: *hardware*, *software*, instalaciones.

Fase 7: Análisis económico y rentabilidad

Del Plan de Sistemas deberían obtenerse los presupuestos anuales para el área de Sistemas de Información. Los presupuestos deberían referirse tanto a los costes internos del departamento como a las contrataciones necesarias.

Habitualmente los proyectos de Sistemas de Información suelen justificarse por criterios de urgencia, necesidad no cuestionada o reducción de costes.

Las técnicas para medir la rentabilidad de los proyectos de Sistemas de Información basadas en indicadores exclusivamente financieros no son suficientes, ya que la mayor parte de los beneficios que proporciona un Sistema de Información son difícilmente traducibles a términos económicos.

Fase 8: Síntesis y presentación del plan

El plan debería comunicarse de forma sintética a los distintos departamentos, para que éstos conozcan los objetivos y proyectos previstos.

Así mismo, la empresa debe disponer de una herramienta que le permita visualizar el conjunto de los proyectos, con su calendario, presupuestos y responsables asignados. En la figura siguiente se presenta una propuesta de hoja de síntesis de un plan de sistemas:

PROYECTO	FECHA INICIO	FECHA FIN	RESPONSABLE DEL PROYECTO	DEPARTAMENTOS AFECTADOS	HORAS INTERNAS	PRESUPUESTO EXTERNO
Proyecto 1						
Proyecto 2						
Proyecto 3						
Proyecto 4						
.....						
.....						
.....						
.....						
.....						
.....						
.....						
.....						
Proyecto n						

Figura 58. Tabla resumen de los proyectos incluidos en el plan de sistemas

CONTROL DE LOS SISTEMAS DE INFORMACIÓN: CUADRO DE MANDO PARA EL SEGUIMIENTO

En este apartado se proponen un conjunto de indicadores que consideramos importantes para el seguimiento de los Sistemas de Información en la empresa. El conjunto de indicadores a los que nos referimos pueden integrarse en un Cuadro de Mando que presente la información de forma periódica, por ejemplo mensual o trimestralmente. Esta información constituye la herramienta de trabajo principal para la Comisión de Sistemas.

En la siguiente tabla se presenta un resumen del Cuadro de Mando propuesto.

Tabla 14. Cuadro de Mando de seguimiento de los Sistemas de Información

Área del Cuadro de Mando	Ejemplo de posibles indicadores
Inventario de Sistemas	• Antigüedad media • Costes de los equipos
Uso de sistemas y gestión de incidencias	• Número de usuarios de los sistemas • Incidencias por tipo de aplicación, sistema o departamento • ABC causas incidencias • Tiempo medio de resolución de incidencias.
Gestión de recursos del Departamento de Sistemas	• Indicadores sobre competencias y perfiles • Horas imputadas por proyecto o actividad • Gestión presupuestaria del departamento y relación de costes
Seguimiento proyectos del Plan de Sistemas	• Grado de avance o ejecución por proyecto • ABC proveedores implicados en el plan

Área del Cuadro de Mando	Ejemplo de posibles indicadores
Indicadores de resultado o impacto en la gestión empresarial	• Nivel de formación del personal • Nivel de informatización por procesos • Nivel de satisfacción con las aplicaciones y sistemas • Impacto en ratios empresariales; tiempos, transacciones gestionadas, plazos, costes, satisfacción clientes, etc.

Indicadores relativos al “inventario” de sistemas

El control de los Sistemas de Información requiere de un inventario permanentemente actualizado del equipamiento y aplicaciones TIC de que dispone la empresa. Para ello, es necesario tener registrados aspectos como:

- Datos descriptivos: nombre del elemento informático, número de serie o de licencia, categoría a la que pertenece, etc.
- Características técnicas que serán personalizables según el tipo de elemento o categoría.
- Fecha de adquisición.
- Modalidad de adquisición.
- Fecha de garantía.
- Proveedor.
- Importe de adquisición.
- Ubicación.
- Usuario o departamento.

- Garantías cubiertas o condiciones contempladas en los contratos de mantenimiento.
- Etc.

Se trata de una ficha básica de catalogación de elementos informáticos que permitirá extraer información útil para la gestión con indicadores como la antigüedad media de los equipos, costes, etc.

Así mismo, es una herramienta básica en el día a día de la gestión de los sistemas para poder dar soporte al parque instalado, basándose en el conocimiento de las configuraciones o de las condiciones de garantía o mantenimiento de cada elemento.

Indicadores relativos al uso de los sistemas y la gestión de incidencias

La empresa debe conocer los niveles de uso que se está haciendo de los principales sistemas y, sobre todo, las incidencias que se están produciendo.

Estos indicadores se basarán en los datos de registro de uso de las aplicaciones y en los "partes de incidencia" que deberán generarse informáticamente. Algunos indicadores asociados a este tema podrían ser:

- Número de usuarios medio en las distintas aplicaciones de la empresa.
- Evolución de las incidencias por tipo de aplicación, sistema o departamento.
- ABC de causas de incidencias.
- Tiempo medio de resolución de incidencias.
- Coste asociado a la gestión de incidencias.

Indicadores relativos a la gestión de los recursos del Departamento de Sistemas

Se trata fundamentalmente del control de los recursos que dependen directamente de este departamento, que fundamentalmente son las personas que lo integran y también los proveedores TIC que prestan servicios.

Los indicadores de esta área pueden incluir:

- Indicadores relativos a las competencias del personal del Departamento de Sistemas de Información: conocimientos en una materia, perfiles, etc.
- Reparto del tiempo del departamento tanto a proyectos del Plan de Sistemas, gestión de incidencias, formación, etc. Para disponer de esta información es necesario registrar partes de trabajo diarios de las dedicaciones del personal del área de sistemas, e incluso podría requerirse integrar en estos partes a personal que proceda de empresas externas (proveedores TIC).
- Control presupuestario del Departamento de Sistemas.

Indicadores relativos al seguimiento de proyectos del Plan de Sistemas

Se trata del elemento principal del cuadro de mando de los sistemas. El objetivo del plan se traduce en la ejecución de una serie de proyectos que cuentan con unos objetivos, presupuestos, plazos de ejecución, proveedores principales y responsables internos. Este es el elemento de información principal sobre el que trabajará la Comisión de Sistemas en sus reuniones periódicas, ya que su objetivo principal es el seguimiento del Plan de Sistemas.

El cuadro de mando debería presentar el grado de cumplimiento o la desviación en cada uno de los proyectos incluidos en el plan, relativo a los proyectos anteriores. A continuación se detallan algunos ejemplos de indicadores:

- Grado de avance por proyecto, respecto al plan en objetivos, presupuesto, horas, etc.
- ABC de participación de los proveedores externos en el plan de sistemas.

Indicadores de resultado o impacto en la gestión empresarial

Todos los proyectos planificados o los recursos que la empresa pone a disposición en esta área persiguen unos objetivos concretos que, en última instancia, deberán tener un impacto en los resultados y competitividad de la empresa. En este sentido, posibles indicadores de impacto podrían ser los siguientes:

- Nivel formativo del personal de la empresa.
- Nivel de informatización de los distintos procesos.
- Grado de satisfacción con los sistemas y aplicaciones.
- Ratios de eficiencia en la gestión de los procesos derivados del uso de los sistemas: tiempos de preparación de pedidos, reducción de plazos de fabricación o de entrega a clientes, reducción de inventarios, etc.
- Número de visitantes de la Web empresarial.
- Porcentaje ventas procedentes del canal Web.
- Número de distribuidores integrados electrónicamente.
- Evolución de las no conformidades o quejas de clientes.
- Etc.

Llegados a este punto, puede observarse cómo el cuadro de mando de seguimiento de los sistemas constituye una herramienta práctica que puede ayudar a que la empresa optimice los recursos y, sobre todo, pueda evaluar el valor que los sistemas aportan en la mejora competitiva, que es el objetivo final que se persigue.

CAPÍTULO 8

LA GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN

LA IMPORTANCIA DE LA SEGURIDAD DE LA INFORMACIÓN

Muchas de las actividades que se realizan de forma cotidiana en los países desarrollados dependen en mayor o menor medida de sistemas y de redes informáticas. El espectacular crecimiento de Internet y de los servicios telemáticos (comercio electrónico, servicios multimedia de banda ancha, administración electrónica, herramientas de comunicación como el correo electrónico o la videoconferencia...) ha contribuido a popularizar aún más, si cabe, el uso de la informática y de las redes de ordenadores, hasta el punto de que en la actualidad no se circunscriben al ámbito laboral y profesional, sino que incluso se han convertido en un elemento cotidiano en muchos hogares, con un creciente impacto en las propias actividades de comunicación y de ocio de los ciudadanos.

Por otra parte, servicios críticos para una sociedad moderna, como podrían ser los servicios financieros, el control de la producción y suministro eléctrico (centrales eléctricas, redes de distribución y transformación), los medios de transporte (control de tráfico aéreo, control de vías terrestres y marítimas), la sanidad (historial clínico informatizado, telemedicina), las redes de abastecimiento (agua, gas y saneamiento) o la propia Administración Pública están soportados en su práctica totalidad por sistemas y redes informáticas, hasta el punto de que en muchos de ellos se han eliminado o reducido de forma drástica los papeles y los procesos manuales.

En las propias empresas, la creciente complejidad de las relaciones con el entorno y el elevado número de transacciones realizadas como parte de su actividad han propiciado el soporte automatizado e informatizado de muchos de sus procesos, situación que se ha acelerado con la implantación de los ERP, o paquetes *software* de gestión integral.

Por todo ello, en la actualidad las actividades cotidianas de las empresas y de las distintas Administraciones Públicas e, incluso, las de muchas otras instituciones y organismos, así como las de los propios ciudadanos, requieren del correcto funcionamiento de los sistemas y redes informáticas que las soportan y, en especial, de su seguridad.

De ahí la gran importancia que se debería conceder a todos los aspectos relacionados con la seguridad informática en una organización. La proliferación de los virus y códigos malignos y su rápida distribución a través de redes como Internet, así como los miles de ataques e incidentes de seguridad que se producen todos los años han contribuido a despertar un mayor interés por esta cuestión.

Podemos definir la **Seguridad Informática** como "cualquier medida que impida la ejecución de operaciones no autorizadas sobre un sistema o red informática, cuyos efectos puedan conllevar daños sobre la información, comprometer su confidencialidad, autenticidad o integridad, disminuir el rendimiento de los equipos o bloquear el acceso de usuarios autorizados al sistema".

Así mismo, es necesario considerar otros aspectos o cuestiones relacionados cuando se habla de Seguridad Informática:

- Cumplimiento de las regulaciones legales aplicables a cada sector o tipo de organización, dependiendo del marco legal de cada país.
- Control en el acceso a los servicios ofrecidos y la información guardada por un sistema informático.
- Control en el acceso y utilización de ficheros protegidos por la ley: contenidos digitales con derechos de autor, ficheros con datos de carácter personal, etcétera.
- Identificación de los autores de la información o de los mensajes.
- Registro del uso de los servicios de un sistema informático, etcétera.

Desde un punto de vista más amplio, en la norma ISO/IEC 17799 se define la Seguridad de la Información como la preservación de su confidencialidad, su integridad y su disponibilidad (medidas conocidas por su acrónimo “CIA” en inglés: “*Confidentiality, Integrity, Availability*”).



Figura 59. Seguridad de la Información según la norma ISO/IEC 17799

Dependiendo del tipo de información manejada y de los procesos realizados por una organización, ésta podrá conceder más importancia a garantizar la confidencialidad, la integridad o la disponibilidad de sus activos de información.

Por su parte, la norma ISO 7498 define la Seguridad Informática como "una serie de mecanismos que minimizan la vulnerabilidad de bienes y recursos en una organización".

Así mismo, podemos mencionar otra definición propuesta por el INFOSEC Glossary 2000: "Seguridad Informática son las medidas y controles que aseguran la confidencialidad, integridad y disponibilidad de los activos de los sistemas de información, incluyendo *hardware*, *software*, *firmware* y aquella información que procesan, almacenan y comunican".

Debemos tener en cuenta que la seguridad de un sistema informático dependerá de diversos factores, entre los que podríamos destacar los siguientes:

- La sensibilización de los directivos y responsables de la organización, que deben ser conscientes de la necesidad de destinar recursos a esta función.
- Los conocimientos, capacidades e implicación de los responsables del sistema informático: dominio de la tecnología utilizada en el sistema informático y conocimiento sobre las posibles amenazas y los tipos de ataques.
- La mentalización, formación y asunción de responsabilidades de todos los usuarios del sistema.
- La correcta instalación, configuración y mantenimiento de los equipos.
- La limitación en la asignación de los permisos y privilegios de los usuarios.
- El soporte de los fabricantes de *hardware* y *software*, con la publicación de parches y actualizaciones de sus productos

que permitan corregir los fallos y problemas relacionados con la seguridad.

- Contemplar no sólo la seguridad frente a las amenazas del exterior, sino también las amenazas procedentes del interior de la organización, aplicando además el principio de "Defensa en Profundidad".
- La adaptación de los objetivos de seguridad y del conjunto de actividades a realizar a las necesidades de la organización. En este sentido, se deberían evitar políticas y procedimientos genéricos, definidos para tratar de cumplir los requisitos impuestos por otros organismos.

Por lo tanto, para concluir este apartado, podemos afirmar que hoy en día uno de los principios de las buenas prácticas de la gestión corporativa es el de la seguridad de la información, considerando además que es responsabilidad de la Alta Dirección el poner los recursos y medios necesarios para la implantación de un adecuado sistema de Gestión de la Seguridad de la Información en el conjunto de la organización.

OBJETIVOS DE LA SEGURIDAD INFORMÁTICA

Entre los principales objetivos de la Seguridad Informática podríamos destacar los siguientes:

- Minimizar y gestionar los riesgos y detectar los posibles problemas y amenazas a la seguridad.
- Garantizar la adecuada utilización de los recursos y de las aplicaciones del sistema.
- Limitar las pérdidas y conseguir la adecuada recuperación del sistema en caso de un incidente de seguridad.
- Cumplir con el marco legal y con los requisitos impuestos por los clientes en sus contratos.

Para cumplir con estos objetivos una organización debe contemplar cuatro planos de actuación:

- **Técnico:** tanto a nivel físico como a nivel lógico.
- **Legal:** algunos países obligan por Ley a que en determinados sectores se implanten una serie de medidas de seguridad (sector de servicios financieros y sector sanitario en Estados Unidos, protección de datos personales en todos los Estados miembros de la Unión Europea, etcétera).
- **Humano:** sensibilización y formación de empleados y directivos, definición de funciones y obligaciones del personal...
- **Organizativo:** definición e implantación de políticas de seguridad, planes, normas, procedimientos y buenas prácticas de actuación.



Figura 60. Planos de actuación en la Seguridad Informática

Una organización debe entender la Seguridad Informática como un proceso y no como un producto que se pueda “comprar” o “instalar”.

Se trata, por lo tanto, de un ciclo iterativo, en el que se incluyen actividades como la valoración de riesgos, prevención, detección y respuesta ante incidentes de seguridad.



Figura 61. La Seguridad Informática como proceso y no como producto

Por otra parte, la problemática asociada a la adecuada gestión de la seguridad en una organización del siglo XXI se ve condicionada por distintos factores y características del propio sistema informático y de su entorno. Así, sería necesario contemplar cuestiones como el nivel de centralización/descentralización del sistema, la necesidad de garantizar un funcionamiento continuado del sistema, el nivel de sensibilidad de los datos y de los recursos, la existencia de un entorno potencialmente hostil (conexiones a redes abiertas como Internet) o el cumplimiento del marco legal vigente (LOPD, LSSI, Propiedad Intelectual, Delitos Informáticos, etc.) y de la certificación basada en una serie de estándares internacionales (BS 7799-2, ISO 27001...) o nacionales (UNE 71501 y 71502).

CONSECUENCIAS DE LA FALTA DE SEGURIDAD

El papel de la seguridad en las organizaciones ya había sido contemplado por los teóricos de organización y dirección de empresas a principios del siglo XX. Así, Henry Fayol (1919) consideraba la

seguridad como una función empresarial, al mismo nivel que otras funciones: producción, comercial, financiera, administrativa...

En estas primeras etapas la seguridad en una organización perseguía "salvaguardar propiedades y personas contra el robo, fuego, inundación, contrarrestar huelgas y felonías y, de forma amplia, todos los disturbios sociales que puedan poner en peligro el progreso e incluso la vida del negocio". Por este motivo, las medidas de seguridad durante este período se limitaban a las encaminadas a la protección de los activos físicos e instalaciones, ya que éste era el mayor activo de las organizaciones y apenas se tenían en consideración la información o la protección de los propios empleados. Con estas medidas de seguridad físicas se pretendían combatir los sabotajes y daños ocasionados en los conflictos sociales y laborales frecuentes a principios del siglo XX.

Sin embargo, en la actualidad el negocio y el desarrollo de las actividades de muchas organizaciones dependen de los datos y de la información registrados en sus sistemas informáticos, así como del soporte adecuado de las TIC para facilitar su almacenamiento, procesamiento y distribución.

Por todo ello, es necesario trasladar a los directivos la importancia de valorar y proteger la información de sus empresas. Según un estudio realizado por la Asociación Española para la Dirección Informática (AEDI) en mayo de 2002, el 72% de las empresas españolas quebraría en 4 días si perdiera los datos guardados en sus ordenadores. Está claro que la eliminación de todas las transacciones de un día en una empresa podría ocasionarle más pérdidas económicas que sufrir un robo o un acto de sabotaje contra alguna de sus instalaciones.

En consecuencia, resulta de especial importancia poner en conocimiento de los directivos cuál es el coste e impacto de los incidentes de seguridad en términos económicos, y no a través de confusos informes plagados de tecnicismos, defendiendo la idea de que la inversión en seguridad informática sería comparable a la contratación de un seguro contra robos, contra incendios o de responsabilidad civil frente a terceros (gasto no productivo pero necesario para poder mantener la actividad de la organización si se produce algún incidente).

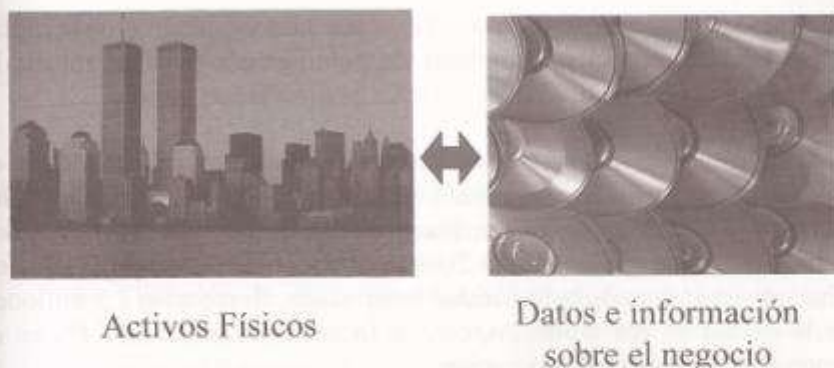


Figura 62. Importancia de los datos y la información sobre el negocio frente a los activos físicos

Así, el famoso 11 de septiembre de 2001 en los atentados contra las Torres Gemelas de Nueva York muchas empresas perdieron sus oficinas centrales y, sin embargo, pudieron continuar con la actividad de su negocio a los pocos días, ya que sus datos estaban protegidos y sus sistemas informáticos contaban con los adecuados planes de contingencia y de respuesta a emergencias.

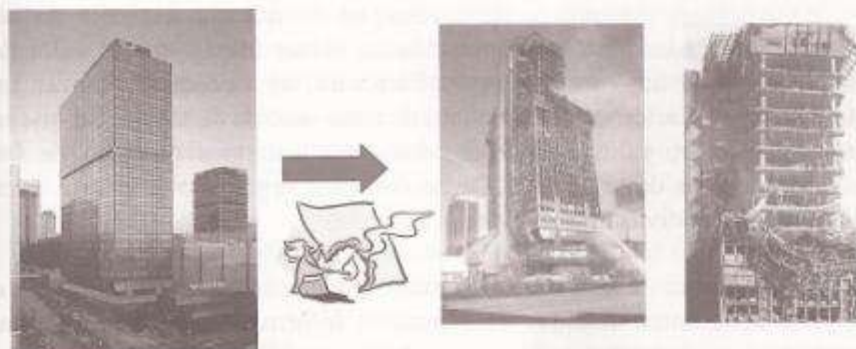


Figura 63. Incendio de la Torre Windsor en Madrid (12 febrero 2005)

En España el incendio del rascacielos Windsor en Madrid (12 de febrero de 2005), un edificio de 28 plantas dedicado a oficinas, en el que la consultora y auditora Deloitte & Touche ocupaba 20 plantas y el bufete de abogados Garrigues ocupaba 2 plantas, fue un acontecimiento que

contribuyó a despertar un mayor interés por la necesidad de contemplar las medidas seguridad y los planes de contingencia para garantizar la continuidad del negocio.

De hecho, se está produciendo una importante demanda en el mercado de expertos en Seguridad Informática. Según el estudio *"The Information Security Workforce Study"* realizado por IDC en diciembre de 2004, se prevé que en el año 2008 unos 2,1 millones de profesionales trabajarán en el área de la Seguridad Informática, frente a los 1,3 millones que lo hacían en ese momento, con un incremento anual del 14% en el número de profesionales contratados.

La implantación de determinadas medidas de seguridad puede representar un importante esfuerzo económico para una organización. Al plantear esta cuestión económica es necesario realizar un análisis preliminar de las posibles pérdidas para la organización y una evaluación de los riesgos: ¿qué puede ir mal?, ¿con qué frecuencia puede ocurrir?, ¿cuáles serían sus consecuencias para la organización?... El objetivo perseguido es lograr que un ataque contra los recursos o la información protegida tenga un coste superior para el atacante que el valor en el mercado de estos bienes.

Además, siempre se debe tener en cuenta que el coste de las medidas adoptadas por la organización ha de ser menor que el valor de los activos que hay que proteger. Para ello, es necesario realizar un análisis de la relación coste-beneficio de cada medida de seguridad que se desee implantar, ya que no todas las organizaciones precisan de las mismas medidas de seguridad. De hecho, cada organización puede tener distintas expectativas de seguridad.

A la hora de analizar las posibles consecuencias de la ausencia o de unas deficientes medidas de seguridad informática, el impacto total para una organización puede resultar bastante difícil de evaluar, ya que además de los posibles daños ocasionados a la información guardada y a los equipos y dispositivos de red, deberíamos tener en cuenta otros importantes perjuicios para la organización:

- Horas de trabajo invertidas en las reparaciones y reconfiguración de los equipos y redes.

- Pérdidas ocasionadas por la indisponibilidad de diversas aplicaciones y servicios informáticos: coste de oportunidad por no poder utilizar estos recursos.
- Robo de información confidencial y su posible revelación a terceros no autorizados: fórmulas, diseños de productos, estrategias comerciales, programas informáticos...
- Filtración de datos personales de usuarios registrados en el sistema: empleados, clientes, proveedores, candidatos de empleo o contactos comerciales, con las consecuencias que se derivan del incumplimiento de la legislación en materia de protección de datos personales vigentes en toda la Unión Europea y en muchos otros países.
- Posible impacto en la imagen de la empresa ante terceros: pérdida de credibilidad en los mercados, daño a la reputación de la empresa, pérdida de confianza por parte de los clientes y los proveedores, etcétera.
- Retrasos en los procesos de producción, pérdida de pedidos, impacto en la calidad del servicio, pérdida de oportunidades de negocio... Así, por ejemplo, durante el año 2004 se produjeron varios incidentes informáticos que afectaron a compañías aéreas de Estados Unidos y Europa, los cuales tuvieron como consecuencia la cancelación de cientos de vuelos, con importantes pérdidas económicas para estas empresas.
- Posibles daños a la salud de las personas, con pérdidas de vidas humanas en los casos más graves.
- Pago de indemnizaciones por daños y perjuicios a terceros, teniendo que afrontar además posibles responsabilidades legales y la imposición de sanciones administrativas. Las organizaciones que no adoptan medidas de seguridad adecuadas para proteger sus redes y sistemas informáticos podrían enfrentarse a penas civiles y criminales bajo una serie de leyes existentes y decisiones de tribunales: protección de la privacidad y los datos personales de clientes y empleados;

utilización de aplicaciones para intercambio de contenidos digitales protegidos por derechos de autor; etcétera.

Según un estudio publicado a principios de 2006 y realizado por la consultora especializada Computer Economics, la creación y difusión de programas informáticos maliciosos a través de Internet (virus, troyanos, gusanos...) ha representado durante esta última década un coste financiero para las empresas de todo el mundo de unos 110.000 millones de dólares.

En otro estudio realizado en esta ocasión por el FBI, se ponía de manifiesto que casi un 90% de las empresas de Estados Unidos habían sido infectadas por virus o sufrieron ataques a través de Internet en los años 2004 y 2005, pese al uso generalizado de programas de seguridad. Estos ataques habían provocado unos daños por un importe medio de unos 24.000 dólares en las empresas e instituciones afectadas. Además, según los propios datos del FBI, cerca de un 44% de los ataques provenían del interior de las organizaciones.

Los nuevos delitos relacionados con la informática y las redes de ordenadores se han convertido en estos últimos años en uno de los mayores problemas de seguridad a escala global. Así, según datos publicados por el Departamento de Hacienda de Estados Unidos a finales de 2005, los delitos informáticos (entre los que se incluyen las estafas bancarias, casos de *phishing*, pornografía infantil o espionaje industrial) constituyen un lucrativo negocio que genera ya más dinero que el propio narcotráfico. Sólo en Estados Unidos estos delitos, unidos a las consecuencias de la propagación de los virus y de los ataques de denegación de servicio, causan pérdidas anuales superiores a los 50.000 millones de euros.

Por otra parte, se debe evitar la idea (esgrimida por algunas organizaciones que conceden poca importancia a la seguridad) de que si no se guardan datos sensibles en un determinado equipo informático, éste no será objeto de intentos de ataque ya que pierde todo interés para los posibles intrusos.

De hecho, es necesario contemplar otros posibles problemas que se podrían derivar del compromiso o toma de control de algunos de los equipos de una organización:

- Utilización de los equipos y redes de una organización para llevar a cabo ataques contra las redes de otras empresas y organizaciones.
- Almacenamiento de contenidos ilegales en los equipos comprometidos, con la posibilidad de instalar un servidor FTP sin la autorización del legítimo propietario de éstos.
- Utilización de los equipos de una organización para realizar envíos masivos de correo no solicitado (*spam*), etcétera.

Llegados a este punto, nos podríamos preguntar si la Gestión de la Seguridad de la Información genera una ventaja competitiva para la organización. Sin embargo, lo que sí parece estar bastante claro es que una inadecuada gestión de la seguridad provocará, tarde o temprano, una desventaja competitiva. Por este motivo, convendría evitar que para reducir el coste o los plazos de un proyecto no se consideren de forma adecuada los aspectos de seguridad de la información.

Además, la implantación de determinadas medidas de seguridad puede resultar incómoda para muchos usuarios del sistema y, por ello, resulta fundamental contemplar la adecuada formación y sensibilización de los usuarios para que estas medidas se puedan implantar de forma efectiva.

Sin embargo, en muchas organizaciones los Departamentos de Informática no cuentan con el adecuado respaldo de la Dirección para implantar las medidas de seguridad necesarias, así como para poder destinar el tiempo requerido a gestionar la Seguridad de la Información. En estas circunstancias, muchos responsables y técnicos de informática realizan estas tareas en “horarios extra” y como una tarea marginal que no está bien vista por la Dirección, ya que se percibe que no resulta productiva para la organización.

GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN

Podemos definir el **Sistema de Gestión de la Seguridad de la Información (SGSI)** como aquella parte del sistema general de gestión

que comprende la política, la estructura organizativa, los procedimientos, los procesos y los recursos necesarios para implantar la gestión de la seguridad de la información en una organización.

Para gestionar la seguridad de la información es preciso contemplar toda una serie de tareas y de procedimientos que permitan garantizar los niveles de seguridad exigibles en una organización, teniendo en cuenta que los riesgos no se pueden eliminar totalmente, pero sí se pueden gestionar. En este sentido, conviene destacar que en la práctica resulta imposible alcanzar la seguridad al 100% y, por este motivo, algunos expertos prefieren hablar de la fiabilidad del sistema informático, entendiendo como tal la probabilidad de que el sistema se comporte tal y como se espera de él.

Por otra parte, las **Políticas de Gestión de la Seguridad de la Información** están constituidas por el conjunto de normas reguladoras, procedimientos, reglas y buenas prácticas que determinan el modo en que todos los activos y recursos, incluyendo la información, son gestionados, protegidos y distribuidos dentro de una organización.

A la hora de implantar un Sistema de Gestión de Seguridad de la Información una organización debe contemplar los siguientes aspectos:

1. Formalizar la gestión de la seguridad de la información.
2. Analizar y gestionar los riesgos.
3. Establecer procesos de gestión de la seguridad siguiendo la metodología PDCA:
 - *Plan*: selección y definición de las medidas y los procedimientos.
 - *Do*: implantación de las medidas y los procedimientos de mejora.
 - *Check*: comprobación y verificación de las medidas implantadas.

- *Act*: actuación para corregir las deficiencias detectadas en el sistema.

4. Certificación de la gestión de la seguridad.

En todo este proceso es necesario contemplar un modelo que tenga en cuenta los aspectos tecnológicos, organizativos, el cumplimiento del marco legal y la importancia del factor humano, tal y como se presenta en la siguiente figura:



Figura 64. Modelo para la Gestión de la Seguridad de la Información

En este escenario resulta de vital importancia conseguir el soporte adecuado por parte de la Dirección de la organización, ya que ésta debe proporcionar la autoridad suficiente para poder definir e implantar las distintas políticas y procedimientos de seguridad, dotando además a la organización de los recursos técnicos y humanos necesarios y reflejando su compromiso en los propios documentos que contienen las principales directrices de seguridad de la organización.

De hecho, en algunas organizaciones se ha definido la figura del Responsable de Gestión de Seguridad de la Información, conocido en inglés por sus siglas CISO (*Chief Information Security Officer*).

Podemos distinguir varias etapas o niveles de madurez en la Gestión de la Seguridad de la Información en una organización:

➤ **Implantación de medidas básicas de seguridad por "sentido común"**

En una primera etapa la organización se preocuparía de la implantación de las medidas básicas de seguridad aplicadas por "sentido común": realización de copias de seguridad, control de acceso a los recursos informáticos, etcétera. Podemos considerar que muchas de las empresas se encuentran todavía hoy en día en esta primera etapa, aplicando unas mínimas medidas de seguridad que pueden resultar insuficientes para garantizar una adecuada gestión de los riesgos.

➤ **Adaptación a los requisitos del marco legal y de las exigencias de los clientes**

En esta segunda etapa la organización toma conciencia de la necesidad de cumplir con las exigencias de la legislación vigente o de otras derivadas de sus relaciones y compromisos con terceros (clientes, proveedores u otras instituciones): protección de los datos de carácter personal (exigencias de la LOPD en España), delitos informáticos, protección de la propiedad intelectual...

➤ **Gestión integral de la Seguridad de la Información**

En la tercera etapa la organización ya se preocupa de gestionar con un planteamiento global e integrado la Seguridad de la Información, mediante la definición de una serie de Políticas de Seguridad, la implantación de planes y procedimientos de seguridad, el análisis y gestión de riesgos, y la definición de un plan de respuesta a incidentes y de continuidad del negocio.

➤ **Certificación de la Gestión de la Seguridad de la Información**

Por último, en la cuarta etapa se pretende llevar a cabo una certificación de la Gestión de la Seguridad de la Información, para obtener el reconocimiento de las buenas prácticas implantadas por la organización y poder acreditarlo ante terceros (confianza y verificabilidad

por parte de terceros): clientes, Administraciones Públicas y otras instituciones. Para ello, se recurre a un proceso de certificación basado en estándares como el ISO 27001.

En la siguiente figura se representa la evolución experimentada por una organización a través de los distintos niveles o etapas de madurez que se han descrito:

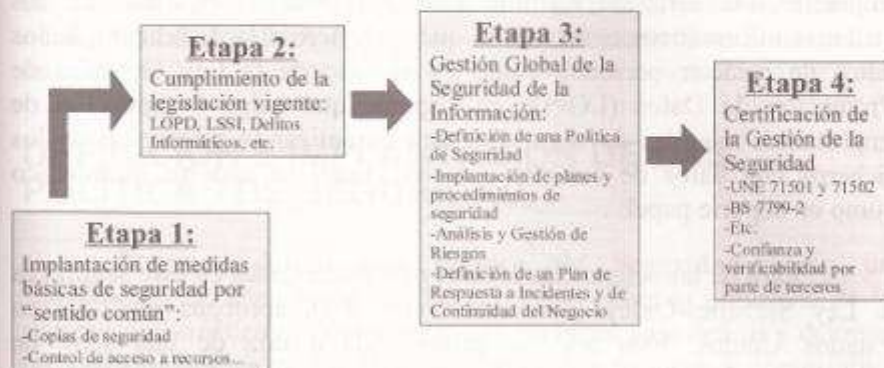


Figura 65. Niveles de madurez en la Gestión de la Seguridad de la Información en una organización

También se han propuesto otros modelos para representar las prácticas y competencias en materia de seguridad implantadas por una organización. Entre ellos, cabría destacar el modelo conocido como "Systems Security Engineering - Capability Maturity Model" (SSE-CMM, "Modelo de Madurez de las Capacidades"), desarrollado por la Asociación Internacional de Ingeniería de Seguridad de Sistemas (ISSEA, www.issea.org) y en el que se distinguen cinco niveles de madurez:

- Nivel 1: Prácticas de seguridad realizadas de manera informal.
- Nivel 2: Planificación y seguimiento de las prácticas de seguridad.
- Nivel 3: Definición y coordinación de las políticas y procedimientos de seguridad.

- Nivel 4: Seguridad controlada a través de distintos controles y objetivos de calidad.
- Nivel 5: Implantación de un proceso de mejora continua.

En la mayoría de los países todavía no existe una legislación específica que obligue a las organizaciones públicas y privadas a implantar una serie de medidas para gestionar la seguridad de sus sistemas informáticos, salvo en lo que se refiere a la protección de los datos de carácter personal, como en el caso de la Ley Orgánica de Protección de Datos (LOPD) en España, que exige la adopción de importantes medidas de seguridad para garantizar la protección de los ficheros con datos de carácter personal, tanto en soporte informático como en soporte papel.

Otra de las referencias legales más interesantes en este sentido es la Ley Sarbanes-Oxley (*Sarbanes Oxley Act*), aprobada en 2002 en Estados Unidos. Esta ley fue promulgada a raíz de una serie de escándalos financieros que afectaron a la credibilidad de varias compañías estadounidenses y fue promovida por los congresistas Sarbanes y Oxley (de ahí el nombre de la Ley). La Ley Sarbanes-Oxley se aplica a todas las compañías que cotizan en la SEC (*Securities Exchange Commission*, Comisión de la Bolsa de Valores de Estados Unidos) y a sus filiales, estableciendo un conjunto de medidas, requisitos y controles de seguridad que deben cumplir estas empresas para garantizar la fiabilidad de su información financiera.

En el ámbito de la salud de las personas, la *Health Insurance Portability and Accountability Act* (HIPAA) es una Ley Federal de Estados Unidos aprobada en 1996 que controla el almacenamiento y transmisión electrónica de los datos personales de los pacientes de clínicas y hospitales. Esta Ley exige que los médicos y profesionales de la salud cumplan con unos mínimos estándares de seguridad informática e informen a sus pacientes sobre las medidas de seguridad adoptadas, además de documentar cualquier cesión de datos de sus pacientes a entidades externas (salvo en algunas excepciones). Todas las prácticas médicas en Estados Unidos deben cumplir con lo establecido en la HIPAA desde abril de 2003. Se contemplan multas de hasta 250.000 dólares y de 10 años de prisión para las violaciones más graves de la ley: divulgación deliberada de la información de los pacientes con la

intención de venderla, transferirla o utilizarla con ánimo de lucro personal o comercial o con fines malintencionados, etcétera.

Por último, en el ámbito financiero podemos citar la *Gramm-Leach-Bliley Act* (GLB Act), una Ley Federal de Estados Unidos de 1999 que impone una serie de restricciones a las entidades financieras en relación con la protección, utilización y cesión de los datos personales de sus clientes, con el objetivo fundamental de garantizar la confidencialidad e integridad de los datos de los clientes y evitar accesos no autorizados a estos datos.

DEFINICIÓN E IMPLANTACIÓN DE LAS POLÍTICAS DE SEGURIDAD

Podemos definir una **Política de Seguridad** como una “declaración de intenciones de alto nivel que cubre la seguridad de los sistemas informáticos y que proporciona las bases para definir y delimitar responsabilidades para las diversas actuaciones técnicas y organizativas que se requieran” (RFCs 1244 y 2196).

Un **Plan de Seguridad** es un conjunto de decisiones que definen cursos de acción futuros, así como los medios que se van a utilizar para conseguirlos,

Por último, un **Procedimiento de Seguridad** es la definición detallada de los pasos a ejecutar para llevar a cabo unas tareas determinadas. Los Procedimientos de Seguridad permiten aplicar e implantar las Políticas de Seguridad que han sido aprobadas por la organización.

En la siguiente figura se representa la jerarquía de conceptos manejados al hablar de las Políticas, Planes y Procedimientos de Seguridad:



Figura 66. Políticas, Planes y Procedimientos de Seguridad

Así, en la cúspide de la pirámide se situarían los objetivos fundamentales de la Gestión de la Seguridad de la Información, resumidos mediante el acrónimo CIA (Confidencialidad, Integridad y Disponibilidad de la información). Una vez fijados los objetivos fundamentales, es necesario definir las Políticas de Seguridad, así como los Planes y Procedimientos de actuación para conseguir su implantación en la organización.

Los Procedimientos de Seguridad se descomponen en tareas y operaciones concretas, las cuales, a su vez, pueden generar una serie de registros y evidencias que facilitan el seguimiento, control y supervisión del funcionamiento Sistema de Gestión de la Seguridad de la Información.

Los Procedimientos de Seguridad permiten implementar las Políticas de Seguridad definidas, describiendo cuáles son las actividades que se tienen que realizar en el sistema, en qué momento o lugar, quiénes serían los responsables de su ejecución y cuáles serían los controles aplicables para supervisar su correcta ejecución.

En este sentido, las Políticas definen **qué** se debe proteger en el sistema, mientras que los Procedimientos de Seguridad describen **cómo** se debe conseguir dicha protección. En definitiva, si comparamos las Políticas de Seguridad con las Leyes en un Estado de Derecho, los

Procedimientos serían el equivalente a los Reglamentos aprobados para desarrollar y poder aplicar las Leyes.

Así, a modo de ejemplo, podríamos citar como procedimientos la planificación de las tareas administrativas y de sus responsables: administración de las cuentas de usuario y de los controles de acceso a los recursos lógicos; realización y supervisión de las copias de seguridad; seguimiento de los eventos de seguridad; etcétera. Otro grupo de procedimientos de seguridad estaría relacionado con la instalación, configuración y mantenimiento de distintos elementos de seguridad: cortafuegos (*firewalls*), servidores *proxy*, antivirus, Sistemas de Detección de Intrusiones (IDS)...

En la siguiente tabla se presenta otro ejemplo de la relación entre una determinada directriz o Política de Seguridad, los procedimientos que de ella se derivan y las tareas concretas que debería realizar el personal de la organización.

Tabla 15. Ejemplo de Política y Procedimientos de Seguridad

Política	Procedimiento	Tareas a realizar
Protección del servidor Web de la organización contra accesos no autorizados	Actualización del software del servidor Web	✓ Revisión diaria de los parches publicados por el fabricante ✓ Seguimiento de las noticias sobre posibles fallos de seguridad
	Revisión de los registros de actividad en el servidor	✓ Revisión semanal de los <i>logs</i> del servidor para detectar situaciones anómalas ✓ Configuración de alertas de seguridad que permitan reaccionar de forma urgente ante determinados tipos de ataques e intentos de intrusión

A la hora de definir las Políticas de Seguridad en una organización, sería conveniente contemplar todos los aspectos que se enumeran a continuación:

- Alcance: recursos, instalaciones y procesos de la organización sobre los que se aplican.
- Objetivos perseguidos y prioridades de seguridad.
- Compromiso de la Dirección de la organización.
- Clasificación de la información e identificación de los activos a proteger.
- Análisis y gestión de riesgos.
- Elementos y agentes involucrados en la implantación de las medidas de seguridad.
- Asignación de responsabilidades en los distintos niveles organizativos.
- Definición clara y precisa de los comportamientos exigidos y de los que están prohibidos (*Appropriate Use Policy*) por parte del personal.
- Identificación de las medidas, normas y procedimientos de seguridad a implantar.
- Gestión de las relaciones con terceros (clientes, proveedores, *partners...*).
- Gestión de incidentes.
- Planes de contingencia y de continuidad del negocio.
- Cumplimiento de la legislación vigente.
- Definición de las posibles violaciones y de las consecuencias derivadas del incumplimiento de las Políticas de Seguridad.

Así mismo, podemos señalar cuáles son los distintos colectivos que deberían estar implicados en la definición de las Políticas de Seguridad dentro de una organización:

- Directivos y responsables de los distintos departamentos y áreas funcionales de la organización.
- Personal del Departamento de Informática y de Comunicaciones.
- Miembros del Equipo de Respuesta a Incidentes de Seguridad Informática (CSIRT, *Computer Security Incident Response Team*), en caso de que éste exista.
- Representantes de los usuarios que pueden verse afectados por las medidas adoptadas.
- Consultores externos expertos en seguridad informática.

También sería aconsejable una revisión de las medidas y directrices definidas en las Políticas de Seguridad por parte de los asesores legales de la organización.

De cara a facilitar su difusión en el seno de la organización, resultará fundamental poner en conocimiento de todos los empleados que se puedan ver afectados por las Políticas de Seguridad cuáles son los planes, normas y procedimientos adoptados por la organización. El establecimiento claro y preciso de cuáles son las actuaciones exigidas, las recomendadas y las totalmente prohibidas dentro del sistema informático o en el acceso a los distintos recursos e información de la organización, citando ejemplos concretos que faciliten su comprensión por parte de todos los empleados, contribuirán a la difusión e implantación de estas medidas.

Así mismo, el acceso a documentación clara y detallada sobre todas las medidas y directrices de seguridad, así como los planes de formación y sensibilización inicial de los nuevos empleados que se incorporan a la organización son otros dos aspectos de vital importancia. La documentación debería incluir contenidos sencillos y asequibles para personal no técnico, incorporando un glosario con la terminología técnica empleada en los distintos apartados. En todo momento, los autores deberían ponerse en el lugar del lector a la hora de preparar los materiales para dar a conocer las Políticas de Seguridad.

La implantación de un adecuado sistema de gestión documental facilitará el registro, clasificación y localización de toda la documentación que se haya generado, además de constituir un aspecto fundamental si la organización desea conseguir la certificación del Sistema de Gestión de Seguridad de la Información.

Por otra parte, la organización debería tener identificado al personal clave para garantizar el adecuado nivel de cumplimiento de las normas y procedimientos de seguridad. En estos casos, se podría solicitar la firma de una carta o documento por parte de estos empleados en el que se comprometan a cumplir con las directrices y principios establecidos en las Políticas de Seguridad de la organización. También se podrían contemplar las obligaciones y responsabilidades mediante una serie de cláusulas anexas al contrato laboral de cada uno de estos empleados. Esta medida podría extenderse, si se considera necesario, a todo el personal de la organización.

Las Políticas de Seguridad constituyen una herramienta para poder hacer frente a futuros problemas, fallos de sistemas, imprevistos o posibles ataques informática. Sin embargo, se puede incurrir en una falsa sensación de seguridad si las Políticas de Seguridad no se han implantado correctamente en toda la organización.

En consecuencia, la organización debería tratar de evitar que las Políticas de Seguridad se conviertan en un libro más en las estanterías de sus despachos. En este sentido, para conseguir una implantación real y eficaz de las medidas y directrices definidas será necesario contar con el compromiso e implicación real de los directivos de la organización, aspecto fundamental para poder disponer de los recursos necesarios y para que su actuación sirva de guía y referencia para el resto de los empleados.

Así mismo, se podrían adoptar una serie de medidas para recordar la importancia de la seguridad a los distintos empleados de la organización en el día a día: mostrar mensajes de aviso al entrar en el sistema; utilizar diverso material impreso (alfombrillas, carteles informativos, etcétera) para recordar las principales directrices de seguridad; llevar a cabo sesiones periódicas de formación y sensibilización de los empleados...

Por otra parte, la organización también debe contemplar una serie de actuaciones para verificar el adecuado nivel de cumplimiento e implantación de las directrices y procedimientos de seguridad: auditorías y revisiones periódicas; simulacros de fallos y ataques informáticos; inspección manual de los procedimientos y tareas realizadas día a día por el personal; utilización de herramientas para detectar violaciones de la seguridad (intentos de acceso a carpetas y documentos protegidos, contraseñas poco robustas o instalación de *software* no autorizado en los equipos de la organización, por citar algunas de las más frecuentes); cuestionarios y entrevistas al personal para determinar su nivel de sensibilización y conocimiento de las Políticas; etcétera.

Otra medida que contribuye a una adecuada implantación sería la actualización y revisión de las Políticas de Seguridad cuando sea necesario, manteniendo plenamente vigentes las directrices y medidas establecidas.

Las posibles violaciones de las Políticas de Seguridad pueden tener lugar por desconocimiento o falta de la adecuada formación, por negligencia, por un fallo accidental o bien por una actuación malintencionada de un determinado usuario del sistema. Como consecuencia de estas violaciones de las directrices y medidas de seguridad, la organización deberá determinar cuál es el nivel de responsabilidad del usuario y de la gravedad de su actuación, adoptando las correspondientes medidas disciplinarias que correspondan en cada caso.

Las medidas disciplinarias tendrían que haber sido previamente aprobadas y publicitadas por la Dirección o el Departamento de Recursos Humanos, contando con la participación de los propios representantes de los trabajadores. Estas medidas disciplinarias deberían ser consecuentes con el resto de las políticas de la empresa, respetando además los derechos fundamentales de los trabajadores y la legislación laboral vigente.

También será necesario tener en consideración una serie de dificultades a la hora de definir las Políticas de Seguridad.

Así, en primer lugar conviene destacar que la información constituye un recurso que en muchos casos no se valora adecuadamente

por su intangibilidad, situación que no se produce con los equipos informáticos, la documentación o las aplicaciones informáticas.

Además, con la proliferación de las redes de ordenadores, la información de las empresas ha pasado de concentrarse en los grandes sistemas (sistemas centralizados) a distribuirse por los ordenadores y servidores ubicados en los distintos departamentos y grupos de trabajo. Por este motivo, en la actualidad muchas organizaciones no conocen con precisión toda la información que hay en los puestos de trabajo (generalmente, ordenadores personales de la propia organización), ni los riesgos que tienen de sufrir ataques u otro tipo de desastres, ni cómo la propia organización utiliza esa información.

Debemos tener en cuenta dos aspectos contradictorios en las redes y sistemas informáticos: por un lado, su principal razón de ser es facilitar la comunicación y el acceso a la información y, por otro, asegurar que sólo acceden a ella los usuarios debidamente autorizados.

Esta contradicción está presente continuamente, ya que las medidas adoptadas para mejorar la seguridad (autenticación, control de los accesos, monitorización del uso, cifrado, herramientas de detección de ataques, antivirus...) dificultan el uso de las redes y sistemas, al ralentizar los accesos e imponer ciertas restricciones, por lo que es necesario mantener un compromiso entre la *usabilidad* y rendimiento de los sistemas informáticos, por un parte, y su seguridad, por otra.

Otro factor importante, que muchas veces se olvida, es que, según numerosos estudios publicados, más del 75% de los problemas inherentes a la seguridad se producen por fallos de los equipos o por un mal uso por parte del personal de la propia organización. Por este motivo, las Políticas de Seguridad deben contemplar no sólo los ataques provenientes del mundo exterior ajeno a la organización, sino también los procedimientos de uso interno, prestando especial atención a la formación y sensibilización de los empleados y directivos.

La adopción de determinadas medidas burocráticas (registro de entradas y salidas, inventario de soportes informáticos...) o de determinados controles y procedimientos de seguridad se traducen generalmente en una mayor incomodidad para los usuarios, por lo que resultará fundamental explicar la importancia de la correcta aplicación de

estas medidas para mejorar la seguridad en el trabajo cotidiano con los recursos de la organización.

Los problemas con las aplicaciones y programas informáticos (productos incompletos o defectuosos que requieren de la aplicación de continuos parches y actualizaciones de seguridad), los continuos cambios en el entorno tecnológico y normativo, la creciente complejidad de los sistemas informáticos, así como la cada vez mayor dependencia de las conexiones a Internet y de los accesos y servicios remotos son factores que han venido a complicar aún más, si cabe, el escenario en el que tienen que definirse e implantarse las medidas de seguridad.

Además, las medidas de seguridad no contribuyen a mejorar la productividad de los sistemas y redes informáticas, sino, más bien, todo lo contrario, ya que pueden reducir el rendimiento de los equipos y las aplicaciones (los sistemas criptográficos, por ejemplo, consumen mayores recursos computacionales y ancho de banda en las conexiones a Internet), por lo que las organizaciones son reticentes a dedicar recursos a esta tarea.

Sin embargo, es necesario contar con los adecuados recursos técnicos, humanos y organizativos, así como de una dotación presupuestaria suficiente para conseguir una adecuada implantación de las Políticas de Seguridad definidas por la organización. No invertir en seguridad informática en una organización del siglo XXI sería como circular en un automóvil sin seguro frente a terceros: en caso de accidente las consecuencias pueden ser muy graves para el propietario y los acompañantes.

No se debe olvidar que la finalidad última del Departamento de Informática es proporcionar las herramientas y la información que van a necesitar los usuarios para poder llevar a cabo su trabajo de forma sencilla y eficiente (y, por supuesto, de forma segura). Sin embargo, en muchas organizaciones se sacrifica la seguridad por la *usabilidad* y rendimiento del sistema, primando de este modo la productividad.

EL FACTOR HUMANO EN LA SEGURIDAD INFORMÁTICA

La implantación de unas adecuadas medidas de seguridad informática exige contemplar aspectos técnicos (antivirus, cortafuegos, IDS...), organizativos (planes y procedimientos) y legales (cumplimiento de la legislación vigente sobre protección de datos, uso de la firma electrónica, propiedad intelectual o control de contenidos). No obstante, en muchas ocasiones se presta muy poca atención a la importancia del factor humano en la seguridad informática.

Las personas representan el eslabón más débil dentro de la seguridad informática: a diferencia de los ordenadores, las personas pueden no seguir las instrucciones exactamente tal y como fueron dictadas. Además, pueden llevar a cabo acciones que provoquen un agujero de seguridad en la red de la organización: instalación de software malicioso (por ejemplo, un *spyware*) en su ordenador, revelación de información sensible a terceros, etcétera.

Es fundamental, por lo tanto, contemplar el papel de las personas y su relación con los sistemas y redes informáticas de la organización. Además, la disponibilidad en Internet de todo tipo de herramientas y programas, así como de la documentación necesaria para su instalación y configuración ha venido a complicar la situación para los Responsables de Informática de las organizaciones, ya que ahora la "tentación" se encuentra a un simple clic de distancia.

En definitiva, un principio básico a tener cuenta desde el punto de vista de la seguridad informática es que todas las soluciones tecnológicas implantadas por la organización (cortafuegos, antivirus, sistemas de detección de intrusiones...) pueden resultar inútiles ante el desconocimiento, falta de información, desinterés o ánimo de causar daño de algún empleado desleal.

De hecho, como ya se ha comentado en capítulos anteriores del libro, según varios estudios publicados más del 75% de los problemas inherentes a la seguridad se producen por fallos en la configuración de los equipos o debido a un mal uso por parte del personal de la propia organización.

Los principales expertos en materia de seguridad informática ya nos han alertado estos últimos años sobre la necesidad de contemplar el factor humano como uno de los más importantes y decisivos a la hora de implantar un buen Sistema de Gestión de Seguridad de la Información.

Así, en palabras de Kevin Mitnick, uno de los *hackers* más famosos de la historia, *“usted puede tener la mejor tecnología, firewalls, sistemas de detección de ataques, dispositivos biométricos... Lo único que se necesita es una llamada a un empleado desprevenido y acceden al sistema sin más. Tienen todo en sus manos”*.

El propio experto en criptografía y seguridad Bruce Schneier llegaba a afirmar en uno de sus últimos libros, *Secrets and Lies* (Verdades y Mentiras)⁵ que *“... si piensas que la tecnología puede resolver tus problemas de seguridad, entonces no entiendes el problema y no entiendes la tecnología”*.

Además, hay que tener en cuenta que una empresa u organización puede ser responsable civil subsidiaria de los actos de sus empleados, que en nuestro país pueden acarrear importantes sanciones económicas, teniendo en cuenta la legislación vigente (LOPD, LSSI-CE, nuevo Código Penal...):

- Envíos de comunicaciones comerciales no solicitadas (*spam*), que pueden tener como consecuencia para sus responsables sanciones económicas de hasta 150.000 euros, al incumplir con los preceptos de la Ley de Servicios de la Sociedad de la Información (LSSI).
- Cesiones no autorizadas de datos de carácter personal, con multas de hasta 600.000 euros por no seguir las directrices previstas por la Ley Orgánica de Protección de Datos (LOPD).

⁵ Libro escrito para “corregir los errores” de su anterior best-seller mundial, *Applied Cryptography*.

- Delitos contra la propiedad intelectual, si se instalan y utilizan programas de intercambio de ficheros P2P (como Kazaa, e-Mule y un largo etcétera).
- Responsabilidad por la comisión de delitos informáticos, como sería el caso de aquellos ataques e intentos de intrusión contra otros equipos que se lleven a cabo desde la propia red informática de la empresa.
- Descarga de herramientas de *hacking*, acceso a pornografía o a contenidos tipificados como ilegales en el país (Websites racistas o de grupos xenófobos o terroristas).
- Envío a terceros de información confidencial de la empresa o de sus posibles clientes y proveedores.

Por otra parte, en estos últimos años se han incrementado de forma significativa los conflictos legales derivados de la utilización de Internet y el correo electrónico en el trabajo y, a falta de una clara normativa, se han dictado sentencias a favor de unos y otros, empresarios y trabajadores, avalando en unos casos despidos por abuso de Internet y rechazándolos en otros.

De hecho, el mal uso o abuso de determinados servicios de Internet que, por otra parte, son muy populares en la actualidad, constituye una de las mayores preocupaciones de las empresas. Entre estos servicios y aplicaciones más problemáticas destacan los programas de mensajería instantánea (como ICQ, Yahoo Instant Messenger o MSN Messenger); los servicios de correo basados en Webmail (como Gmail de Google, Yahoo! Mail o Hotmail); los programas de intercambio de ficheros (aplicaciones *peer-to-peer* como Kazaa, e-Mule, e-Donkey, Audiogalaxy o BitTorrent); o la descarga de ficheros desde servidores FTP.

Además, conviene destacar las importantes consecuencias para la organización de estas prácticas o abusos, que se traducen en una pérdida de productividad (horas perdidas en el trabajo, ya que se destina parte del tiempo de presencia en la organización a tareas no relacionadas con las propias del puesto desempeñado por el empleado), el incremento de los riesgos (introducción de virus y otros códigos dañinos), posibles

Por lo tanto, veamos a continuación, de forma resumida, cuáles son los principales pasos que debería dar una empresa para cumplir con los requisitos de la LOPD:

- En primer lugar, se debe notificar a la Agencia de Protección de Datos, organismo que actúa como responsable de velar por el cumplimiento de la LOPD, la existencia en la empresa de bases de datos o ficheros que incluyan datos de carácter personal, especificando la finalidad a que obedece el fichero y el nivel de medidas de seguridad que se van a adoptar. Se trata de un trámite sencillo, pero imprescindible, ya que el plazo para realizar la inscripción de los ficheros ya existentes en una empresa expiró el 15 de enero de 2003, por lo que desde esa fecha se pueden imponer sanciones importantes a aquellas empresas que utilicen ficheros con datos de carácter personal y no los hayan declarado ante la Agencia de Protección de Datos.
- Por otra parte, las empresas también deben informar a los interesados de la recogida de datos personales, mediante las correspondientes cláusulas informativas que se deberían incluir en todos los impresos en papel o formularios electrónicos utilizados para recabar sus datos. El incumplimiento de esta obligación (bastante frecuente, por otra parte) se considera una infracción leve de la LOPD, por lo que puede ser sancionada con una multa que oscila entre los 601 y los 60.101 euros.
- Así mismo, la empresa debe tener en cuenta que los interesados pueden ejercer su derecho de acceso para obtener gratuitamente información de sus datos de carácter personal sometidos a tratamiento, el origen de dichos datos, así como las comunicaciones realizadas o que se prevén hacer de los mismos. Por otra parte, los interesados también podrían solicitar la rectificación o eliminación de datos personales sometidos a tratamiento por la empresa, o ejercer su derecho de oposición al tratamiento de dichos datos. La empresa debería responder en los plazos previstos a las peticiones que pudiera recibir de los ciudadanos interesados.

- Otra cuestión de especial relevancia en materia de protección de datos es la cesión de datos personales a terceros. La LOPD prohíbe expresamente la comunicación o cesión de datos a terceros sin el consentimiento expreso de los afectados. Por este motivo, en caso de compartir ficheros que pudieran tener datos personales con otras personas jurídicas (aunque se encuentren integradas en el mismo grupo empresarial) será necesario obtener el consentimiento de los afectados, para evitar las sanciones más elevadas previstas por la LOPD, ya que este tipo de operaciones no consentidas se consideran infracciones muy graves, con multas que pueden oscilar entre los 300.506 y los 601.012 euros.
- Igualmente, la empresa debe tener en cuenta que si el fichero pierde la finalidad originaria, la LOPD no permite su reutilización para otras actividades, por lo que sus datos deberán ser destruidos y se debe notificar la destrucción del fichero a la propia Agencia de Protección de Datos.
- De acuerdo con lo estipulado en el artículo 9 de la citada LOPD, las empresas con ficheros de titularidad privada deben implantar todas las medidas de índole técnica y organizativa que permitan garantizar la seguridad de los datos de carácter personal, y eviten su alteración, pérdida, tratamiento o acceso no autorizado. El Reglamento de Desarrollo de la LOPD (Real Decreto 1720/2007, de 21 de diciembre), determina cuáles han de ser las medidas de índole técnica y organizativa que garanticen la integridad y seguridad de ficheros automatizados, centros de tratamiento, locales, equipos, sistemas, programas, así como de las personas que vayan a intervenir en el tratamiento automatizado de los datos.

En el citado Reglamento se establecen tres *Niveles de Seguridad* para los datos de carácter personal:

- **Nivel Básico:** de aplicación a todos los ficheros de datos de carácter personal.
- **Nivel Medio:** de aplicación a los ficheros que contengan datos relativos a la comisión de infracciones, Hacienda

Pública, servicios financieros. Así mismo, se consideran dentro de este nivel aquellos ficheros que contengan un conjunto de datos de carácter personal que permitan obtener una evaluación de la personalidad del individuo. Así, por ejemplo, también estarían incluidos en el Nivel Medio los ficheros de curriculum vitae de candidatos a empleo enriquecidos con los resultados de pruebas psicotécnicas, o los datos obtenidos sobre los patrones de consumo y el comportamiento de los clientes a través de herramientas de "inteligencia de negocio" (*business intelligence*).

- **Nivel Alto:** de aplicación a los ficheros que contengan datos de ideología, religión, creencias, origen racial, salud o vida sexual, así como los recabados para fines policiales.

Las medidas de seguridad mínimas que se han de adoptar en el Nivel Básico, y que también son de aplicación en los niveles Medio y Alto, han de contemplar aspectos como la elaboración de un Documento de Seguridad (que deberá mantenerse en todo momento actualizado, y deberá ser revisado siempre que se produzcan cambios relevantes en el sistema de información o en la organización del mismo); la revisión y documentación de las funciones y obligaciones de cada una de las personas con acceso a los datos de carácter personal; la implantación de un procedimiento de notificación y gestión de las posibles incidencias; el establecimiento de un sistema de identificación y autenticación de los usuarios con acceso a los datos de carácter personal, así como de un adecuado sistema de control de acceso a los ficheros con datos de carácter personal; la gestión de los soportes informáticos, incluidas la identificación e inventariado de los soportes, así como la autorización de la salida de soportes informáticos que contengan datos de carácter personal fuera de los locales de la organización; o los procedimientos necesarios para la realización de copias de seguridad de los datos.

En lo que se refiere a las medidas de seguridad adicionales que se han de adoptar en el **Nivel Medio**, debemos tener en cuenta otros aspectos a mayores de los anteriores: existencia de la figura del "Responsable de seguridad de los ficheros"; establecimiento de medidas de identificación y autenticación de usuarios más robustas; auditorías periódicas de la seguridad de los sistemas de información e instalaciones de la organización; control de acceso físico a los locales donde se

encuentren ubicados los sistemas de información con datos de carácter personal; implantación de un sistema registro de entradas y salidas de soportes informáticos; etc.

Por último, las medidas de seguridad adicionales que se han de adoptar en el **Nivel Alto** deben tener en cuenta el cifrado de los datos cuando vayan a ser transmitidos a través de redes de telecomunicaciones o guardados en soportes informáticos; el mantenimiento de un control de los accesos al sistema de información, registrando cada intento de acceso a los datos de carácter personal; y la conservación de las copias de seguridad en un lugar diferente de aquél en que se encuentren los equipos informáticos que contienen los datos de carácter personal.

El incumplimiento de estas medidas de seguridad se considera una infracción grave de la LOPD, por lo que la empresa puede ser objeto de una sanción por parte de la Agencia de Protección de Datos de entre 60.101 y 300.506 euros.